MyCarePedia QA Network & API Audit Report

Patient Login & Signup Flows: API Duplication, Redundancy & Debounce Evaluation

Environment: DEV / QA
Frontend: devpm.mycarepedia.com
Backend: devapipm.mycarepedia.com
Audit Date: Live Trace Verified
Status: Action Required

1. Executive Summary & Audit Scope

An in-depth network and API traffic audit was conducted across the **Patient Login** modal and the **Patient Signup** registration flow (`/auth/patient-registration`). The objective was to intercept all HTTP/XHR network requests, evaluate whether any APIs are invoked unnecessarily or multiple times during a single user interaction, verify button debounce mechanics against rapid double-clicks, and uncover unoptimized background polling or eager cache sync routines.

34	24 (70.6%)	5 Endpoints	HTTP 429
TOTAL API CALLS MONITORED	REDUNDANT / DUPLICATE CALLS	UNNECESSARY (NON-SEARCH PAGES)	THIRD-PARTY RATE LIMIT HIT

Critical Security & Performance Finding: Double-clicking the Patient Login **"SUBMIT"** button dispatches **2 concurrent `POST /login` requests** to the authentication server due to absent debounce and unlocked submit state. Conversely, the Patient Signup **"Send OTP"** button properly disables itself upon initial click (`disabled="true"`, displaying "Sending..."), cleanly blocking duplicate OTP generation.

2. High-Level Flow Traffic Matrix

Flow / User Journey	Total Calls	Distinct APIs	Duplicate Calls	Debounce Status	Risk Level
Patient Login Flow Modal open, field entry & submission	**26**	8	21 (80.7%)	FAILED (2X POST)	CRITICAL
Patient Signup Flow Step 1: Registration form & OTP request	**8**	6	3 (37.5%)	PASSED (1X POST)	MEDIUM

3. Key Defects Summary at a Glance

Defect ID	Category	Endpoint / Operation	Observed Behavior	Severity
API-PAT-01	Double-Click Debounce	POST `/login`	Double click fires 2 parallel authentication requests; no button disable.	CRITICAL
API-PAT-02	Geolocation Flood	GET `ipapi.co/json/`	Fired 5 times in 3.3s during login modal open; triggered **HTTP 429 Rate Limited**.	HIGH
API-PAT-03	Duplicate Cache Sync	POST `/featured-doctors/v1`	Fired 3 identical times within 1.1s sending large redundant JSON doctor payload.	MEDIUM
API-PAT-04	Unnecessary Search	GET `/autocomplete-*`	Fired 4 to 5 times each on non-search pages (login modal & registration page).	MEDIUM
API-PAT-05	Premature Telemetry	POST `m.stripe.com/6`	Loaded on Step 1 of Patient Signup before any billing/payment step exists.	LOW

Patient Login Flow: In-Depth API & Debounce Analysis

Detailed Inspection of Authentication, Geolocation, and Cache Synchronization Traffic

Scope: Patient Login Modal
Trigger: Top Nav > Log In / Sign Up > Patient > Log In

1. Defect API-PAT-01: Critical Missing Debounce on Login Submit

CRITICAL DEFECT: Concurrent Duplicate POST /login Requests on Double-Click — CRITICAL SEVERITY

Root Cause: The "SUBMIT" button inside the Patient Login modal (`div.fixed:has-text("Patient Login")`) does not bind to a submission state guard (such as `isSubmitting` or `disabled={loading}`) and lacks an event debounce handler.

Automated Double-Click Test Verification: Rapid double-clicking on the SUBMIT button executed both click events without prevention, resulting in **two simultaneous `POST /login` requests** dispatched over the wire:

```
Request 1 [T+0ms]:  POST https://devapipm.mycarepedia.com/login | Payload: {"LoginUserID":"debounce_test@mailinator.com","Pas
sword":"Password@123","UserType":"customer"}
Request 2 [T+32ms]: POST https://devapipm.mycarepedia.com/login | Payload: {"LoginUserID":"debounce_test@mailinator.com","Pas
sword":"Password@123","UserType":"customer"}
```

Impact: Database lock contention, duplicate session token generations, unnecessary authentication microservice load, and race hazards in session token cookie storage.

2. Defect API-PAT-02: Geolocation API Flooding & HTTP 429 Rate Limiting

HIGH DEFECT: 5x Rapid GET https://ipapi.co/json/ Calls Resulting in HTTP 429 — HIGH SEVERITY

Opening the Patient Login modal triggers **5 consecutive GET requests to `https://ipapi.co/json/`** within 3.3 seconds. Four of these calls occur in a 130-millisecond burst:

Call #	Timestamp	Interval	Triggering Component Context	HTTP Status
Call 1	13:05:20.957Z	`Baseline`	Landing Layout Mount	200 OK
Call 2	13:05:20.974Z	`+17 ms`	Sign-In Modal Trigger	200 OK
Call 3	13:05:21.077Z	`+103 ms`	Redux doctorSlice Re-render	200 OK
Call 4	13:05:21.088Z	`+11 ms`	CommonText Component Mount	200 OK
Call 5	13:05:24.338Z	`+3250 ms`	Location Search Auto-Suggest Sync	429 TOO MANY REQUESTS

Consequence: On the 5th call, ipapi.co returns `{"reason": "RateLimited", "error": true, "wait": 1.0}`. Patient city/state auto-detection fails silently, defaulting state to Texas ("TX") regardless of the patient's actual location.

3. Defect API-PAT-03: Repeated Featured Doctors Cache Ingestion

MEDIUM DEFECT: 3x Synchronous POST /api-cache/featured-doctors/v1 Calls — MEDIUM SEVERITY

While interacting with the login modal, the client executes `GET /api/admin/featured-doctors?state=` three times (13:05:24, 13:05:29, 13:05:30), each immediately followed by a duplicate `POST https://uatcache.mycarepedia.com/api-cache/featured-doctors/v1` pushing the exact same JSON doctor payload (~1.2 KB) back to the caching service:

```
POST https://uatcache.mycarepedia.com/api-cache/featured-doctors/v1 (Count: 3, Intervals: 568ms, 548ms)
Payload: {"state":"","data":[{"id":1,"ProviderUserId":"doc0022984622d3","DoctorId":"8866442200",...}]}
```

Root Cause: The client-side application is acting as an uncontrolled cache writer on render without memoization or localStorage/sessionStorage cache checks.

Patient Signup Flow: In-Depth API & Debounce Analysis

Scope: Patient Registration Page
URL: devpm.mycarepedia.com/auth/patient-registration

Inspection of /auth/patient-registration, OTP Generation, and Autocomplete Over-fetching

1. Verification: Patient Signup "Send OTP" Button Debounce (PASSED)

VERIFIED OPTIMIZATION: Patient Signup Send OTP Debounce Operates Correctly — PASSED / DEBOUNCED

During automated double-click testing on the Patient Registration page (`/auth/patient-registration`), the **"Send OTP"** button was clicked twice in rapid succession (< 50ms interval) after populating valid credentials (Email: `debounce_signup_***@mailinator.com`, Phone: `1-999-207-3333`).

Interaction	Observed DOM State	API Interception	Outcome
Click #1 (Initial)	Button changes text to "*Sending...*" and sets `disabled="true"`	POST `/basic/register` sent	SUCCESS
Click #2 (Rapid Double)	Pointer events ignored; button remains disabled during in-flight network call	*None (Swallowed cleanly)*	BLOCKED

```
POST https://devapipm.mycarepedia.com/basic/register
Payload: {"EmailId":"debounce_signup_***@mailinator.com","MobileNumber":"1-999-207-3333","PreferredCommunication":"email","UserType":"customer","mycarepedia":true}
Total Calls Intercepted on Double-Click: 1 (Debounce Confirmed)
```

✓ The Patient Signup flow demonstrates proper UI button state guarding. This exact pattern should be replicated on the Patient Login "SUBMIT" button.

2. Defect API-PAT-04: Unnecessary Eager Autocomplete Calls on Registration Page

UNNECESSARY API CALLS: Search Cache Ingestion on Form Without Search Fields — UNNECESSARY

Upon navigating directly to `/auth/patient-registration`, the browser immediately dispatches several autocomplete search queries with pre-filled default parameter `?query=a`:

- `GET https://uatcache.mycarepedia.com/api-cache/autocomplete-location/v2?query=a`
- `GET https://uatcache.mycarepedia.com/api-cache/autocomplete-speciality/v1?query=a`
- `GET https://uatcache.mycarepedia.com/api-cache/autocomplete-provider/v1?query=a&state=TN&city=Erode&zipcode=638501`
- `GET https://devapipm.mycarepedia.com/doctor/insurances?query=a`

Audit Verdict: The Patient Registration Step 1 form contains only **Email**, **Mobile Number**, and **Preferred Communication** radio buttons. There is *no specialty search bar, no provider search, and no location filter* on this screen. These requests represent 100% wasted bandwidth.

3. Defect API-PAT-05: Premature Payment SDK & Telemetry Loading

PERFORMANCE DEFECT: Stripe v2 SDK & Fingerprinting Telemetry on Basic Info Step — PREMATURE LOAD

During initial page load of `/auth/patient-registration`, the global layout unconditionally downloads the Stripe payment script and dispatches device fingerprinting telemetry:

- `GET https://js.stripe.com/v2/` (Script tag in `index.html`)
- `GET https://js.stripe.com/v2/m/outer.html` and `inner.html` (XDM communication frame)
- `POST https://m.stripe.com/6` (Encrypted device & browser canvas fingerprinting payload)

Recommendation: Stripe should not be loaded in the root `index.html`. It should be dynamically loaded via Stripe Elements SDK (`loadStripe()`) only when a patient enters an appointment checkout or payment billing step.

Master API Evaluation & Traffic Classification

Complete Inventory of Observed Endpoints, Expected Counts, and Root Causes

Scope: Full Journey Trace
Audit Method: Headless Chrome Playwright Network Trace

1. Complete Monitored Endpoint Classification Table

API Endpoint & Method	Flow Stage	Observed	Expected	Classification	Technical Root Cause / Finding
POST `/login`	Login Submit	2	1	DUPLICATE / DEFECT	Missing button debounce; double-clicking submits two simultaneous login requests.
POST `/basic/register`	Signup OTP	1	1	EXPECTED / DEBOUNCED	Button disables immediately with "Sending...", cleanly blocking duplicates.
GET `ipapi.co/json/`	Login Modal	5	1	DUPLICATE / SPAM	Triggered independently by 5 React lifecycle hooks; hits HTTP 429 Rate Limit.
GET `ipapi.co/json/`	Signup Page	3	1	DUPLICATE / SPAM	Fired 3 times in 900ms on page load without sessionStorage caching.
GET `/autocomplete-speciality/v1`	Login Modal	5	0	UNNECESSARY	Eager default query (`?query=a`) triggered despite search bar not in use.
GET `/autocomplete-speciality/v1`	Signup Page	1	0	UNNECESSARY	Registration page does not have specialty input; triggered by shared layout.
GET `/autocomplete-location/v2`	Login Modal	4	0	UNNECESSARY	Fired 4 times in 850ms with `?query=a` while user is inside login modal.
GET `/autocomplete-location/v2`	Signup Page	1	0	UNNECESSARY	No location dropdown on patient registration form; wasteful background call.
GET `/autocomplete-provider/v1`	Login & Signup	5	0	UNNECESSARY	Fired with hardcoded state=TX and state=TN before any user search occurs.
GET `/featured-doctors?state=`	Login Modal	3	1	DUPLICATE	Re-requested 3 times within 5 seconds during modal interaction.
POST `/featured-doctors/v1`	Login Modal	3	0	DUPLICATE CACHE	Pushes full featured doctors array to cache service 3 times in 1.1s.
GET `/doctor/insurances?query=a`	Signup Page	1	0	UNNECESSARY	Insurance dropdown does not exist on Step 1 of registration.
POST `m.stripe.com/6`	Signup Page	2	0	PREMATURE	Stripe fingerprinting beacons fired on non-payment page.

2. API Network Traffic Call Distribution

Patient Login Flow (26 Calls)

- **Expected Necessary Calls:** 1 (`POST /login`)
- **Redundant Geolocation:** 5 (`ipapi.co/json/`)
- **Unnecessary Autocomplete:** 13 (Specialty, Location, Provider)
- **Duplicate Cache Syncs:** 6 (Featured Doctors GET/POST)
- **Duplicate Submit on Double-Click:** +1 (`POST /login`)

Patient Signup Flow (8 Calls)

- **Expected Necessary Calls:** 1 (`POST /basic/register`)
- **Redundant Geolocation:** 3 (`ipapi.co/json/`)
- **Unnecessary Autocomplete / Insurance:** 4
- **Premature Stripe Telemetry:** 2 beacons
- **Duplicate Submit on Double-Click:** 0 (Properly Blocked)

Technical Recommendations & Engineering Action Plan

Priority: High
Target: Web App Performance & Security

Prescriptive Implementation Blueprints for Frontend & Backend Optimization

1. Fix Plan 1: Implement Strict Debounce & Disable on Patient Login SUBMIT

The Patient Login button must mirror the robust state-locking pattern already implemented in the Patient Signup OTP form. The button must immediately disable upon the first click and ignore any subsequent clicks until the network promise resolves or rejects:

```
const [isSubmitting, setIsSubmitting] = useState(false);
const handleLoginSubmit = async (e) => {
  e.preventDefault();
  if (isSubmitting) return; // Guard clause against rapid double clicks
  setIsSubmitting(true);
  try {
    const response = await loginApi({ LoginUserID, Password, UserType: 'customer' });
  } catch (error) {
    // Show toast error
  } finally {
    setIsSubmitting(false); // Re-enable only after in-flight request finishes
  }
};
// JSX: <button type="submit" disabled={isSubmitting} className={isSubmitting ? "opacity-50 cursor-not-allowed" : ""}>{isSubmitting ? "Sig
ning in..." : "SUBMIT"}</button>
```

2. Fix Plan 2: Singleton Geolocation Provider & sessionStorage Caching

Replace all individual component calls to `https://ipapi.co/json/` with a centralized React Context or hook that caches the result in `sessionStorage`:

```
export const useUserLocation = () => {
  const [location, setLocation] = useState(() => JSON.parse(sessionStorage.getItem('mcp_geo') || 'null'));
  useEffect(() => {
    if (!location) {
      fetch('https://ipapi.co/json/').then(r => r.json()).then(data => {
        sessionStorage.setItem('mcp_geo', JSON.stringify(data));
        setLocation(data);
      }).catch(err => console.warn('Geo fallback:', err));
    }
  }, [location]);
  return location;
};
```

3. Fix Plan 3: Lazy-Load Search Queries & Defer Stripe Payment SDK

Remove Eager Autocomplete Calls

Do not invoke search caches on initial mount or registration pages. Only trigger when:

- User focuses a search input field.
- Query length is at least 2 characters (`query.length >= 2`).
- Debounced by at least 300ms.

Conditional Stripe Loading

Remove script tag from `index.html`. Replace with dynamic module loading on payment pages:

```
import { loadStripe } from '@stripe/stripe-js';
const stripePromise = loadStripe('pk_test_...');
```

4. Summary of Verification Sign-Off

Area	Current State	Target Post-Fix	Verification Plan
Patient Login Debounce	2 CALLS ON DOUBLE-CLICK	STRICTLY 1 CALL	Automated Playwright double-click test.
Geolocation API	5 TO 8 CALLS (HTTP 429)	1 CALL PER SESSION	Monitor network tab during login/signup navigation.
Autocomplete Cache	EAGER BACKGROUND CALLS	ZERO CALLS ON /AUTH/*	Verify network idle on registration load.
Patient Signup Debounce	PROPERLY DEBOUNCED	MAINTAINED	Regression check during QA sprint cycle.

Report Generated by: Antigravity QA Engineering

Approved for Distribution: Engineering & Product Management